ESCUELA SUPERIOR de Innovación y Tecnología

ESIT - ESTANCIA PROFESIONAL

Formato Oficial de Bitácora Semanal

Versión para seguimiento grupal y evaluación individual

Propósito del instrumento: Esta versión íntegra elementos de control grupal y trazabilidad individual para sustentar la evaluación del desempeño técnico, el cumplimiento, la participación y los aportes verificables de cada integrante del equipo.

Fase:	Fase 2
Nombre del proyecto:	**WAF Shield Cloud – Implementación de Seguridad Perimetral para Aplicaciones en la Nube**
Equipo:	SN-2
Tutor:	Carlos G. Rodriguez
Ciclo:	06
Semana No.:	Semanas 4-5 | Fecha (inicio - fin): 20 de octubre al 8 de noviembre de 2026
Nombre Y Rol:	Julissa Girón, Líder de Proyecto Jr. Y documentador jr.
Nombre Y Rol:	Edwin Gómez, Analista QA / Seguridad Jr.
Nombre Y Rol:	Mauricio Martinez, Ingeniero de Seguridad Cloud Jr.
Nombre Y Rol:	David Guzmán, Ingeniero de Infraestructura Jr.
Nombre Y Rol:	Jhony Jiménez, Desarrollador Web Jr

Instrucción de uso: La bitácora debe completarse semanalmente. Las evidencias deben ser concretas, atribuibles y verificables: enlaces, commits, rutas de archivos, capturas, pruebas, documentos o configuraciones. No se recomienda registrar aportes genéricos sin evidencia técnica.

Estancia Profesional
ESCUELA SUPERIOR DE INNOVACIÓN Y TECNOLOGÍA

1. Información general de la semana

Campo	Registro de la semana
Integrantes presentes:	Julissa Girón, Edwin Gómez, Mauricio Martínez, David Guzmán y Jhony Jiménez.
Roles activos	• Líder de Proyecto Jr. y Documentador Jr.: Julissa Girón • Ingeniero de Seguridad Cloud Jr.: Mauricio Martínez • Ingeniero de Infraestructura Jr.: David Guzmán • Desarrollador Web Jr.: Jhony Jiménez • Analista QA / Seguridad Jr.: Edwin Gómez
Fase actual	Fase 2 - implementación del entorno protegido y configuración del WAF.
Entregable objetivo	Aplicación de prueba accesible, protección perimetral integrada, reglas iniciales y evidencias técnicas.
Acuerdos clave	Mantener una arquitectura común, atribuir cada aporte a su responsable y separar resultados locales, funcionales y cloud.
Estado general	La implementación y las pruebas están reportadas; la revisión documental continúa y la consulta de logs queda en seguimiento para la Fase 3

Campos sugeridos: Integrantes presentes, roles activos, fase actual, entregable objetivo, acuerdos clave, riesgos iniciales y estado general de avance.

2. Actividades realizadas

Actividad	Descripción técnica	Responsable	Evidencia verificable
Coordinación y documentación	Organizó el seguimiento en Kanban, revisó observaciones de Fase 1 y recopiló las bitácoras para consolidación.	Julissa Girón	GitHub Projects y carpeta Fase 2 de Julissa.
Aplicación web de prueba	Desarrolló el portal Node.js/Express y reportó 5/5 pruebas funcionales locales; /login es demostrativo, sin autenticación real.	Jhony Jiménez	Código, test/app.test.js y capturas locales en GitHub.
Despliegue y perímetro cloud	Reporta Cloud Run, balanceador HTTPS, NEG y Cloud Armor con reglas SQLi/XSS; restringió el acceso directo al servicio.	David Guzmán	Evidencias E2-39 a E2-57; E2-54 verificables en: https://github.com/Esme8906/Prototipo-de-seguridad-perimetral-WAF-SN2-ESIT-2026/tree/main/Fase%202%20%E2%80%93%20Implementaci%C3%B3n%20y%20Configuraci%C3%B3n%20del%20WAF/David_Guzman registra una consulta de Cloud Logging sin solicitudes WAF; la atribución de bloqueos por logs sigue pendiente
Sandbox WAF local	Configuró un WAF local en Nginx para pruebas y un script de apoyo previo a la subida a Google Cloud.	Mauricio Martínez	nginx_waf.conf, scripts y capturas; Mauricio aclara que su script se usa para pruebas locales antes de subirlo a Google.

Actividad	Descripción técnica	Responsable	Evidencia verificable
Preparación QA	Preparó casos de verificación, resultados esperados y evidencias por recopilar; no reporta pruebas de seguridad ejecutadas.	Edwin Gómez	Matriz OWASP 2025, hoja Verificacion Fase 2 e informe QA.

3. Herramientas y servicios utilizados

Herramienta / servicio	Propósito	Observaciones
GitHub Projects y GitHub	Organizar tareas, responsables, seguimiento y evidencias.	Vista Actividades de las fases y carpetas individuales.
Node.js, Express, npm y VS Code y codex	Desarrollar y validar localmente el portal de prueba.	Pruebas funcionales locales reportadas por Desarrollo Web.
Docker, Nginx y Python requests	Probar localmente el filtrado y la limitación de solicitudes.	Sandbox de Seguridad Cloud; separado de Cloud Armor.
Google Cloud	Desplegar y proteger la aplicación.	Cloud Run, Cloud Build, Cloud Armor, balanceador HTTPS, NEG y Cloud Logging.
Excel y Word	Preparar matriz de verificación e informes técnicos.	Matriz QA, bitácoras e informes individuales.

4. Problemas detectados y análisis

Problema	Impacto	Causa probable	Evidencia
Diferencias entre estados reportados y evidencias disponibles para cerrar la bitácora grupal.	Puede incorporarse un estado de avance que no coincida con su respaldo.	La información está distribuida entre bitácoras, capturas, archivos y enlaces que deben cotejarse.	Bitácoras individuales y evidencias registradas en el repositorio.

Problema	Impacto	Causa probable	Evidencia
No se recuperaron logs de tráfico WAF para atribuir algunos bloqueos a reglas concretas.	Limita la trazabilidad de los eventos de seguridad.	La consulta de Cloud Logging no devolvió registros HTTP del balanceador.	Referencia E2-54 en la bitácora de Infraestructura.
El acceso directo al endpoint de Cloud Run debía quedar restringido.	El servicio podría omitir la capa perimetral.	Configuración inicial del ingreso del servicio.	David reporta HTTP 404 directo y HTTP 200 por balanceador en E2-55/E2-56.
La aplicación tenía ajustes pendientes de presentación y navegación.	Podía dificultar la revisión funcional del portal.	La distribución inicial de elementos y un enlace requerían corrección.	Captura previa al ajuste y reporte de Desarrollo Web.
Diferencias entre el estado reportado por los integrantes y la evidencia para cerrar la bitácora	Puede quedar una bitácora grupal con afirmaciones o estados no respaldados.	Como líder y documentadora debo contrastar los informes individuales con los archivos y estados visibles antes de consolidarlos.	La evaluación de Fase 1 señaló referencias/estados por conciliar; la líder reporta que Fase 2 fue entregada y que falta verificar el repositorio.
Aislamiento de red entre contenedores Docker en Windows (error redirigiendo Nginx a localhost:3000).	Fallo inicial de comunicación Proxy-Backend.	Nginx dentro del contenedor busca el puerto internamente.	Sección 2 del informe.

5. Soluciones aplicadas

Solución aplicada	Problema asociado	Responsable	Evidencia
Revisión inicial y cotejo de bitácoras con las evidencias disponibles; se solicitaron confirmaciones sobre datos por aclarar.	Diferencias entre estados reportados y evidencias disponibles.	Julissa Girón y responsables de cada rol.	Bitácoras del equipo y referencias del repositorio.
Se configuró el acceso del contenedor Nginx al backend mediante host.docker.internal.	Aislamiento de red entre contenedores Docker en Windows.	Mauricio Martínez.	Configuración de ejecución y capturas del sandbox.
Se restringió el ingreso externo directo a Cloud Run para encaminar el tráfico por el balanceador.	Riesgo de eludir la capa perimetral.	David Guzmán.	E2-55 y E2-56; HTTP 404 por URL directa y HTTP 200 por balanceador.
Se habilitó Cloud Logging y se revisaron consultas de tráfico; la atribución de bloqueos sigue pendiente.	Falta de registros de tráfico WAF.	David Guzmán.	E2-54; consulta sin registros de solicitudes WAF.
Se ajustó la presentación del portal y se ejecutaron nuevamente pruebas funcionales locales.	Problemas de navegación y presentación del prototipo.	Jhony Jiménez.	Capturas locales y registro de npm test 5/5.

6. Estado del proyecto esta semana

Área	Estado	Comentarios
Aplicación de prueba	Reportada como desplegada	Jhony desarrolló el portal; David reporta Cloud Run. /healthcheck respondió HTTP 200 por el balanceador.
WAF cloud	Política waf-shield-policy reportada	David reporta waf-shield-policy aplicada al backend con reglas SQLi/XSS. Mauricio aclara que el script de su bitácora es para pruebas locales antes de subir a

Área	Estado	Comentarios
		Google.
WAF local y matriz QA	Pruebas locales reportadas; matriz preparada	Mauricio reporta HTTP 403 en Nginx local. Edwin preparó casos; no reporta ejecución de pruebas QA.
Logs y consolidación documental	Pendientes de cierre	No se atribuyeron bloqueos a reglas mediante logs.
Coordinación y kanban de Fase 2, Consolidación de la bitácora grupal	completada	Las tarjetas de Fase 2 aparecen en la vista del proyecto, Consolidación completada

7. Plan de trabajo para la próxima semana

Tarea próxima semana	Responsable	Fase	Entregable esperado
Revisar registros del balanceador y documentar eventos WAF disponibles.	David Guzmán / Seguridad Cloud	Fase 3	Registros consultados y limitaciones documentadas.
Completar y ejecutar la matriz de pruebas con rutas y criterios confirmados.	Edwin Gómez con el equipo	Fase 3	Resultados, solicitudes permitidas/bloqueadas y evidencias.
Comprobar funciones de la aplicación a través de la URL protegida.	Jhony Jiménez	Fase 3	Rutas verificadas y capturas; distinguirlas de pruebas WAF.
Actualizar README y preparar tablero y carpetas de Fase 3.	Julissa Girón	Inicio Fase 3	Repositorio y Kanban alineados con los entregables.
Monitorear y analizar la telemetría de seguridad en Cloud Logging para identificar bloqueos de solicitudes maliciosas y revisar posibles falsos positivos.	Mauricio Martínez/ David Guzmán	Fase 3	Registros revisados y resultados documentados, incluyendo los eventos disponibles y las limitaciones encontradas

8. Aportes individuales verificables

Integrante	Rol	Tarea técnica específica realizada	Componente / entregable afectado	Evidencia verificable	Resultado
Julissa Girón	Líder de Proyecto Jr. y Documentadora Jr.	Organizó tareas, revisó observaciones previas y recopiló bitácoras.	Kanban y documentación del equipo.	Vista de GitHub Projects y carpeta de Julissa.	Consolidación en revisión; verificar publicación del archivo grupal.
Edwin Gómez	Analista QA / Seguridad Jr.	Preparó matriz y casos de verificación.	Matriz de verificación Fase 2.	Excel, hoja Verificacion Fase 2 e informe QA.	Casos preparados; pruebas de seguridad no ejecutadas en este registro.
Mauricio Martínez	Ingeniero de Seguridad Cloud Jr.	Configuró Nginx local, realizó pruebas y preparó un script para pruebas previas a la subida a Google.	Proxy local y scripts de seguridad.	nginx_waf.conf, scripts y capturas.	HTTP 403 reportado en el sandbox local
David Guzmán	Ingeniero de Infraestructura Jr.	Desplegó Cloud Run y configuró balanceador, NEG, Cloud Armor e ingreso.	Entorno cloud protegido.	E2-39 a E2-57 y configuración documentada.	Pruebas HTTP reportadas; logs de tráfico WAF pendientes.
Jhony	Desarrollad	Desarrolló el portal Express y	Rutas	Repositorio,	5/5

Integrante	Rol	Tarea técnica específica realizada	Componente / entregable afectado	Evidencia verificable	Resultado
Jiménez	or Web Jr.	ejecutó pruebas funcionales locales.	/healthcheck, /search, /comments, /login y /admin.	test/app.test.js y capturas locales.	pruebas locales; /login no implementa autenticación real.

Uso obligatorio: Cada fila debe corresponder a un aporte individual atribuible. Ejemplos válidos: commit identificado, sección redactada en un documento, prueba ejecutada, configuración aplicada, endpoint implementado, consulta corregida, vista del dashboard ajustada o script de simulación mejorado.

9. Cumplimiento individual y responsabilidad

Integrante	Tarea asignada	Estado	Observación del cumplimiento	Seguimiento requerido
Julissa Girón	Coordinar seguimiento, recopilar aportes y consolidar documentación.	En revisión	Una sección reporta cierre; otras mantienen el cotejo y publicación pendientes.	Confirmar estados, evidencias y ubicación del archivo grupal.
Edwin Gómez	Preparar matriz y casos QA con resultados esperados.	Completado para preparación	La bitácora distingue los casos preparados de las pruebas no realizadas.	Actualizar y ejecutar en Fase 3.
Mauricio Martínez	Preparar y probar localmente el proxy perimetral; documentar script.	Completado en sandbox local	Mauricio aclara que su script se usa para pruebas locales previas a la subida a Google Cloud.	Registrar el alcance local

Integrante	Tarea asignada	Estado	Observación del cumplimiento	Seguimiento requerido
David Guzmán	Desplegar y proteger el entorno cloud.	Completado según su reporte	Valida 200/403 y restricción directa; atribución por logs pendiente.	Revisar Cloud Logging y completar referencias faltantes.
Jhony Jiménez	Desarrollar y probar localmente la aplicación.	Completado local	5/5 pruebas funcionales; no representan pruebas WAF.	Comprobar rutas a través de la URL protegida en Fase 3.

10. Participación en documentos técnicos y entregables

Integrante	Documento / entregable	Sección elaborada o corregida	Tipo de aporte	Evidencia
Julissa Girón	GitHub Projects y bitácora	Organización de tareas y recopilación/consolidación de aportes.	Gestión y documentación.	Vista de proyectos y carpeta Julissa; publicación grupal por confirmar.
Edwin Gómez	Matriz e informe QA	Casos de verificación, resultados esperados y evidencias previstas.	Preparación QA.	Archivo Excel y documento Word indicados en su bitácora.
Mauricio Martínez	Informe individual y archivos locales	Sandbox Nginx local, scripts de pruebas y script de apoyo previo a la subida a Google.	Configuración y documentación técnica.	Archivos y capturas locales referidos; la política cloud se documenta en la bitácora de David.

Integrante	Documento / entregable	Sección elaborada o corregida	Tipo de aporte	Evidencia
David Guzmán	Informe de infraestructura y evidencias cloud	Cloud Run, Cloud Armor, balanceador, pruebas y diagnóstico de logs.	Implementación cloud.	Bitácora y evidencias E2-39 a E2-57.
Jhony Jiménez	Aplicación web y pruebas	Portal Node.js/Express, rutas y pruebas funcionales locales.	Desarrollo y verificación funcional.	Repositorio y test/app.test.js.

11. Pruebas, configuraciones o validaciones por estudiante

Integrante	Tipo de prueba / configuración	Elemento intervenido	Resultado	Evidencia
Julissa Girón	Revisión de tablero y visibilidad de tareas.	GitHub Projects.	Tarjetas reportadas visibles; es validación de gestión, no de seguridad.	Captura del tablero en su carpeta del repositorio.
Edwin Gómez	Preparación de casos, sin ejecución de pruebas de seguridad.	Matriz QA.	Casos y resultados esperados preparados.	Excel y captura indicados en su bitácora.
Mauricio Martínez	Rate limiting local y denegación de /admin.	Nginx en Docker, backend Node.js.	HTTP 403 reportado en pruebas locales.	Scripts Python y capturas de consola referidas.
David Guzmán	Conectividad y pruebas WAF cloud.	Balanceador HTTPS, Cloud Armor y Cloud Run.	HTTP 200 legítimo; SQLi/XSS 403; URL directa run.app 404.	E2-51 a E2-57; revisar archivos independientes y logging.

Integrante	Tipo de prueba / configuración	Elemento intervenido	Resultado	Evidencia
Jhony Jiménez	Suite funcional local de la aplicación.	Rutas del prototipo Express.	5/5 pruebas aprobadas localmente; no valida el WAF.	test/app.test.js y registro local referido.

12. Participación en demo o explicación técnica (Solo utilizar en entrega del informe final)

Integrante	Parte explicada o demostrada	Evidencia presentada	Nivel de dominio observado

13. Reflexión individual por rol

Integrante	Rol	Qué realizó	Dificultad técnica enfrentada	Cómo la resolvió	Próximo paso
Julissa Girón	Líder / Documentadora Jr.	Organizó tareas y recopiló registros del equipo.	Conciliar estados y respaldos de distintas bitácoras.	Revisión por rol y solicitud de confirmaciones.	Cerrar publicación grupal y alinear README.
Edwin Gómez	Analista QA / Seguridad Jr.	Preparó matriz y casos de verificación.	Faltan confirmar rutas y flujos para algunos casos.	Marcó esos datos como pendientes.	Actualizar y ejecutar matriz en Fase 3.

Integrante	Rol	Qué realizó	Dificultad técnica enfrentada	Cómo la resolvió	Próximo paso
Mauricio Martínez	Ingeniero de Seguridad Cloud Jr.	Configuración de la capa mitigada local en Nginx, desarrollo de la suite de pruebas HTTP en Python y estructuración del script para GCP.	Resolver la comunicación de red entre el contenedor Proxy Nginx y el backend de Node.js en Windows Docker Desktop.	Utilizando la bandera de red --add-host=host.docker.internal:host-gateway al instanciar el contenedor de Nginx.	Monitorear resultados de intento de ataques en Armor en la Fase 3.
David Guzmán	Ingeniero de Infraestructura Jr.	Encadenó Cloud Run, serverless NEG, backend global, Cloud Armor y frontend HTTPS; restringió el ingreso y verificó el comportamiento por HTTP	Evitar el bypass del perímetro y atribuir los bloqueos a reglas específicas sin registros WAF.	Restringió el ingreso y verificó las respuestas HTTP; la falta de logs impidió atribuir inequívocamente los 403 a una regla	Completar la observabilidad y mantener controles de costos, certificados y mínimo privilegio.
Jhony Jiménez	Desarrollador Web Jr.	Desarrolló el portal y sus rutas de prueba.	Ajustes de presentación y navegación.	Corrigió la interfaz y probó localmente.	Verificar funciones por la URL protegida.

14. Registro consolidado de evidencias

No.	Descripción de la evidencia	Tipo	Responsable	Enlace / ruta / referencia
EV01	Kanban de Fase 2 y estructura individual del repositorio.	Capturas	Julissa Girón	GitHub Projects y carpeta Julissa_Giron/capturas_pruebas_documentos_configuraciones. https://github.com/users/Esme8906/projects/2/views/1 https://github.com/Esme8906/Prototipo-de-seguridad-perimetral-WAF-SN2-ESIT-2026/tree/main/Fase%202%20%E2%80%93%20Implementaci%C3%B3n%20y%20Configuraci%C3%B3n%20del%20WAF
EV02	Código del portal y pruebas funcionales locales 5/5.	Repositorio / resultado	Jhony Jiménez	Fase 2/Jhony_Jimenez/capturas_pruebas_documentos_configuraciones; test/app.test.js. https://github.com/Esme8906/Prototipo-de-seguridad-perimetral-WAF-SN2-ESIT-2026/tree/main/Fase%202%20%E2%80%93%20Implementaci%C3%B3n%20y%20Configuraci%C3%B3n%20del%20WAF/Jhony_Jimenez/capturas_pruebas_documentos_configuraciones
EV03	Matriz de verificación y reporte técnico QA.	Excel / Word	Edwin Gómez	Carpeta individual de Edwin en Fase 2; confirmar acceso a archivos citados. https://github.com/Esme8906/Prototipo-de-seguridad-perimetral-WAF-SN2-ESIT-

No.	Descripción de la evidencia	Tipo	Responsable	Enlace / ruta / referencia
				2026/tree/main/Fase%202%20%E2%80%93%20Implementaci%C3%B3n%20y%20Configuraci%C3%B3n%20del%20WAF/Edwin_Gomez/capturas_pruebas_documentos_configuraciones
EV04	Sandbox WAF local, scripts de pruebas y alcance del script de apoyo previo a la subida a Google.	Configuración / capturas	Mauricio Martínez	Carpeta individual de Mauricio; política Cloud Armor activa reportada en la bitácora de David. https://github.com/Esme8906/Prototipo-de-seguridad-perimetral-WAF-SN2-ESIT-2026/tree/main/Fase%202%20%E2%80%93%20Implementaci%C3%B3n%20y%20Configuraci%C3%B3n%20del%20WAF/Mauricio_Martinez/capturas_pruebas_documentos_configuraciones
EV05	Cloud Run, Cloud Armor, balanceador y validaciones HTTP.	Capturas E2	David Guzmán	E2-39 a E2-57; E2-51/E2-53 sin imagen independiente y E2-54 sin registros WAF. https://github.com/Esme8906/Prototipo-de-seguridad-perimetral-WAF-SN2-ESIT-2026/tree/main/Fase%202%20%E2%80%93%20Implementaci%C3%B3n%20y%20Configuraci%C3%B3n%20del%20WAF/David_Guzman/capturas_pruebas_documentos_configuraciones
EV06	Reuniones y organización del equipo.	Capturas	Julissa Girón / equipo	reunion 22_10_2026.jpeg y reunion 5_11_2026.jpeg; revisar contenido y

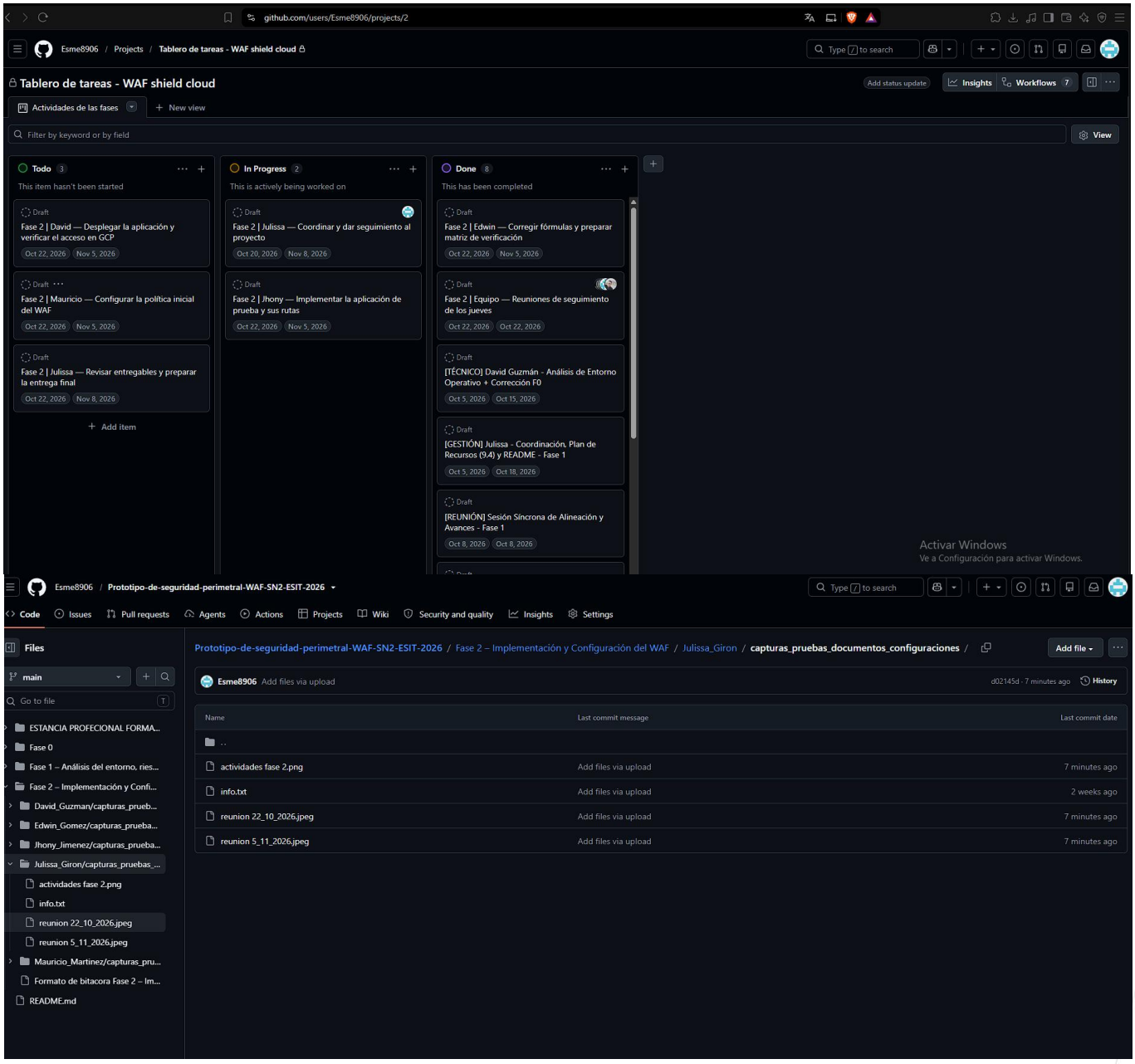
No.	Descripción de la evidencia	Tipo	Responsable	Enlace / ruta / referencia
				acuerdos. https://github.com/Esme8906/Prototipo-de-seguridad-perimetral-WAF-SN2-ESIT-2026/tree/main/Fase%202%20%E2%80%93%20Implementaci%C3%B3n%20y%20Configuraci%C3%B3n%20del%20WAF/Julissa_Giron

Criterio de calidad de la evidencia: La evidencia debe permitir verificar el aporte sin ambigüedad. Se recomienda incluir identificadores concretos: URL, commit hash, nombre de archivo, ruta de carpeta, nombre de prueba, nombre de servicio, fecha y referencia del estudiante responsable.

15.Registro de evidencias

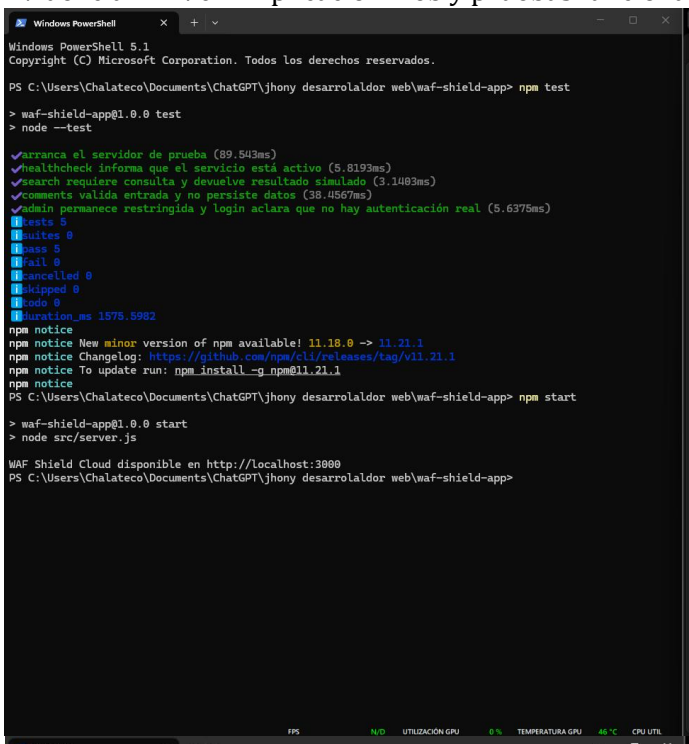
Descripción de las evidencias registradas:

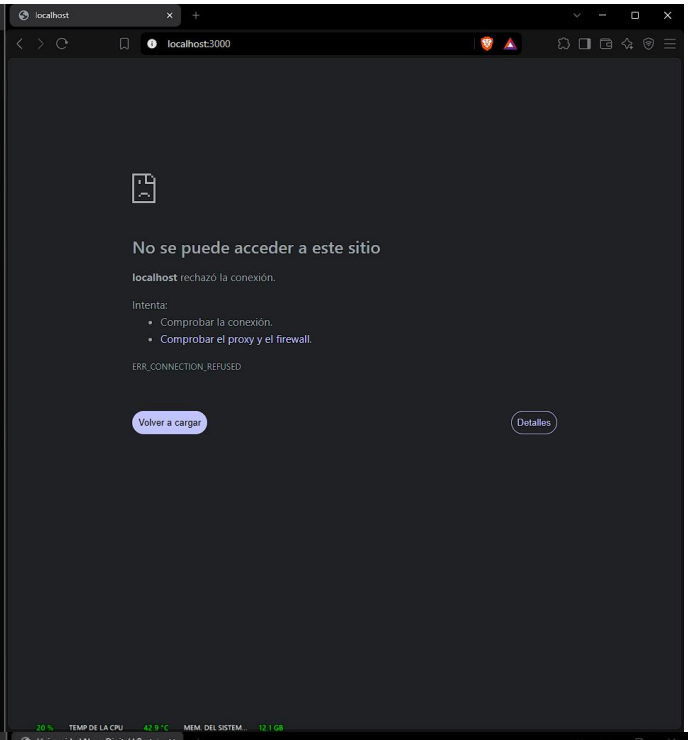
Evidencia 1: EV01 - Kanban, estructura del repositorio y coordinación del equipo.

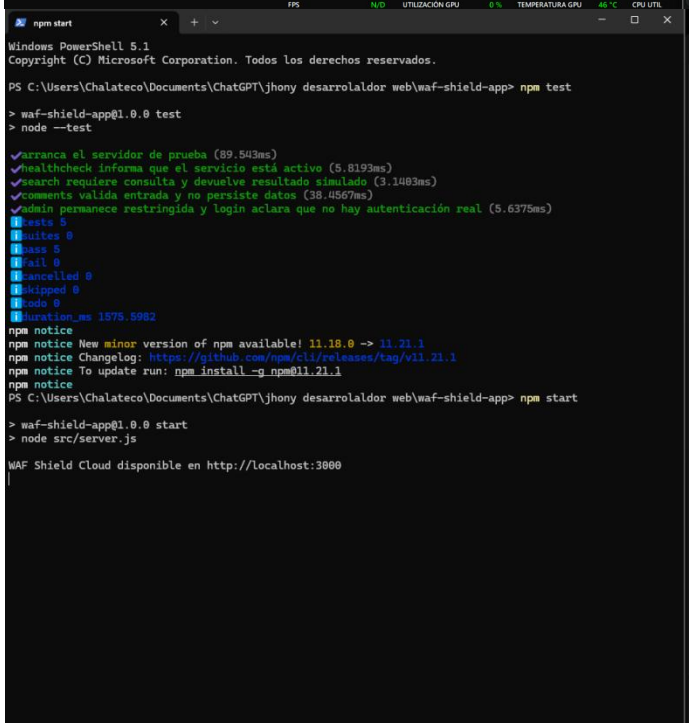


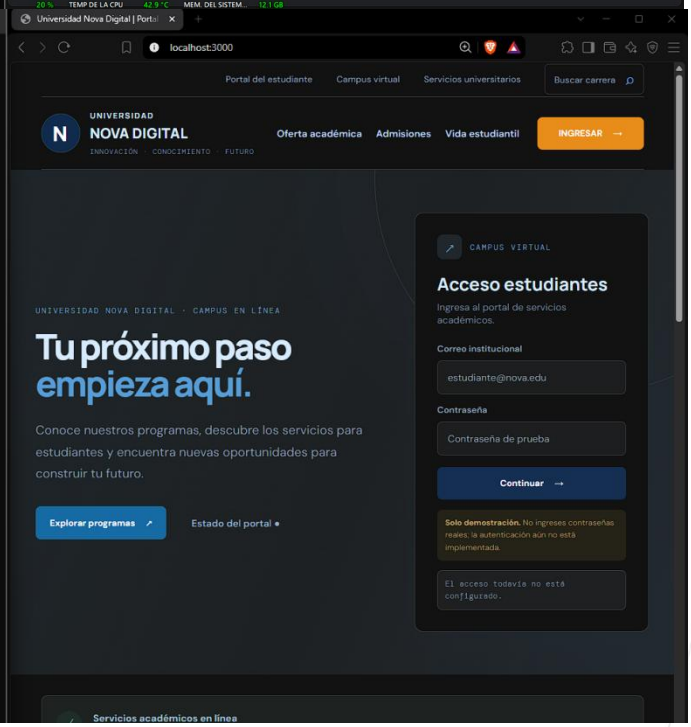
ESCUELA SUPERIOR de Innovación y Tecnología

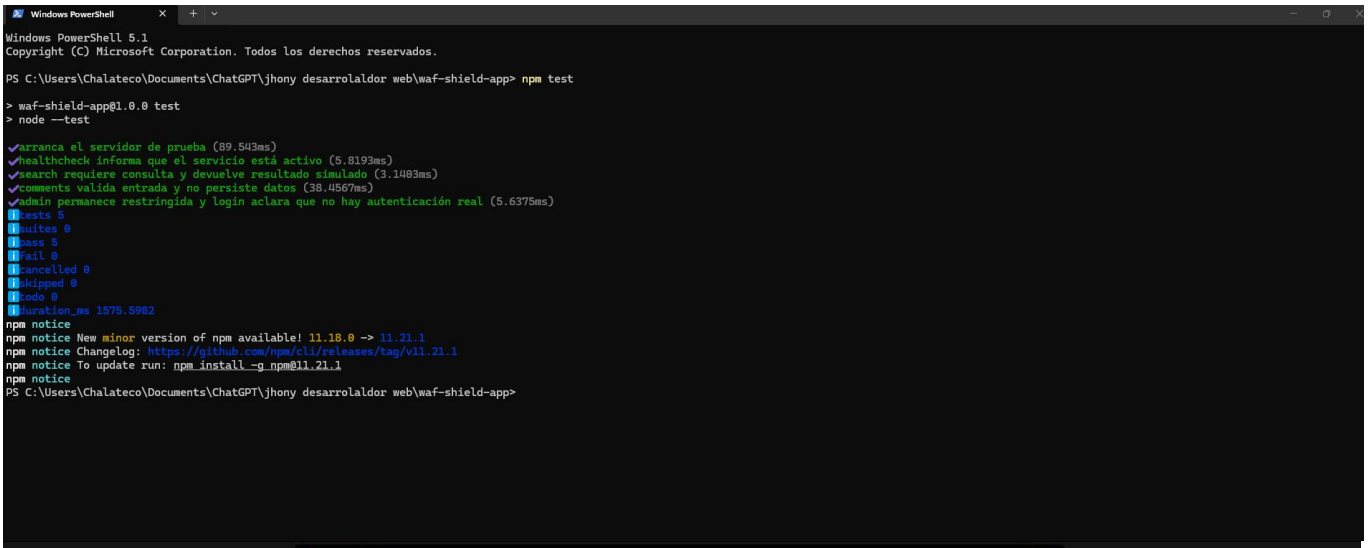
Evidencia 2: EV02 - Aplicación web y pruebas funcionales locales

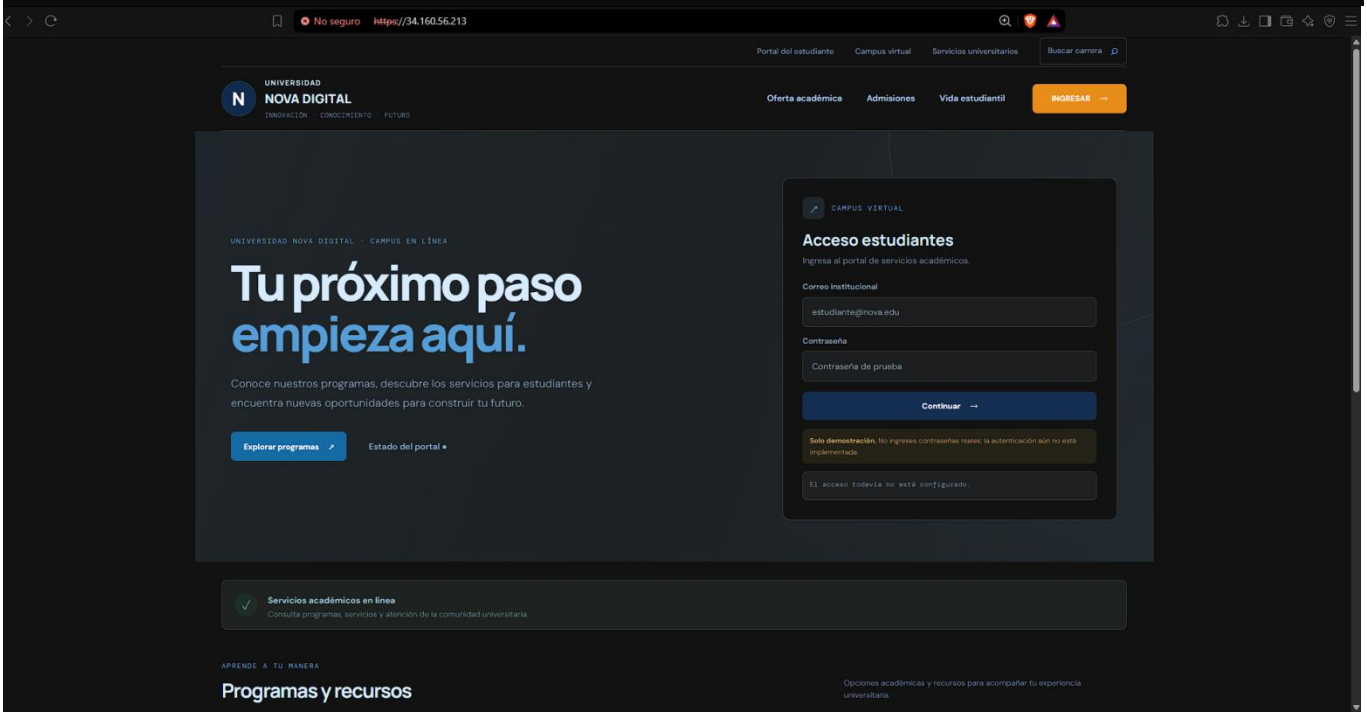









Windows PowerShell
Windows PowerShell 5.1
Copyright (C) Microsoft Corporation. Todos los derechos reservados.
PS C:\Users\Chalateco\Documents\ChatGPT\jhony desarrolaldor web\waf-shield-app> npm test
> waf-shield-app@1.0.0 test
> node --test
✔arranca el servidor de prueba (89.543ms)
✔healthcheck informa que el servicio está activo (5.8193ms)
✔search requiere consulta y devuelve resultado simulado (3.1403ms)
✔comments valida entrada y no persiste datos (38.4567ms)
✔admin permanece restringida y login aclara que no hay autenticación real (5.6375ms)
ℹtests 5
ℹsuites 0
ℹpass 5
ℹfail 0
ℹcancelled 0
ℹskipped 0
ℹtodo 0
ℹduration_ms 1575.5982
npm notice
npm notice New minor version of npm available! 11.18.0 -> 11.21.1
npm notice Changelog: https://github.com/npm/cli/releases/tag/v11.21.1
npm notice To update run: npm install -g npm@11.21.1
npm notice
PS C:\Users\Chalateco\Documents\ChatGPT\jhony desarrolaldor web\waf-shield-app>


No seguro https://34.160.56.213
Portal del estudiante
Campus virtual
Servicios universitarios
Buscar carrera
UNIVERSIDAD
NOVA DIGITAL
INNOVACIÓN · CONOCIMIENTO · FUTURO
Oferta académica
Admisiones
Vida estudiantil
INGRESAR
UNIVERSIDAD NOVA DIGITAL · CAMPUS EN LÍNEA
Tu próximo paso
empieza aquí.
Conoce nuestros programas, descubre los servicios para estudiantes y encuentra nuevas oportunidades para construir tu futuro.
Explorar programas
Estado del portal
CAMPUS VIRTUAL
Acceso estudiantes
Ingresa al portal de servicios académicos.
Correo institucional
estudiante@nova.edu
Contraseña
Contraseña de prueba
Continuar
Solo demostración. No ingreses contraseñas reales; la autenticación aún no está implementada.
El acceso todavía no está configurado.
Servicios académicos en línea
Consulta programas, servicios y atención de la comunidad universitaria.
APRENDE A TU MANERA
Programas y recursos
Opciones académicas y recursos para acompañar tu experiencia universitaria.

Evidencia 3: EV03 y EV04 - Matriz QA y pruebas del sandbox WAF local.

Matriz Riesgos OWASP 2025 WAF Shield Cloud Edwin Gomez - Fase 2 - Excel

Matriz preparada para futura ejecucion. No se reportan pruebas ejecutadas ni resultados obtenidos.

Alcance: se definen casos, resultados esperados y evidencia a recopilar. La ejecucion y el ajuste de falsos positivos quedan para la fase correspondiente en el plan del proyecto.

ID caso	ID riesgo	Categoria OWASP	Componente o ruta	Caso de verificacion preparado	Resultado esperado	Evidencia a recopilar	Estado
V-01	A01	Control de acceso roto	Rutas protegidas / panel administrativo	Intentar acceder sin credenciales o con permisos insuficientes.	Acceso denegado y recurso protegido no disponible.	Respuesta HTTP, captura y registro disponible.	Preparado
V-02	A02	Configuracion incorrecta de seguridad	Servidor web / WAF / proxy	Revisar metodos permitidos, cabeceras y rutas publicadas.	Solo deben estar disponibles los elementos aprobados en el diseno.	Captura de configuracion y respuesta HTTP.	Preparado
V-03	A03	Cadena de suministro de software	Dependencias / repositorio	Revisar dependencias declaradas y versiones utilizadas.	Dependencias identificadas y sin componentes no autorizados.	Listado de dependencias y captura del repositorio.	Preparado
V-04	A04	Fallos criptograficos	Inicio de sesion / transmision	Comprobar uso de HTTPS y ausencia de datos sensibles visibles.	Conexion segura y sin datos sensibles expuestos en la URL.	Captura del navegador, certificado y respuesta HTTP.	Preparado
V-05	A05	Inyeccion	Formularios / parametros / API	Enviar una cadena de prueba controlada en una entrada definida.	La entrada debe tratarse de forma segura y segun el control configurado.	Respuesta HTTP, captura y registro del WAF.	Preparado
V-06	A06	Diseno inseguro	Flujos criticos de la aplicacion	Revisar un flujo repetitivo o una secuencia no prevista.	El flujo debe conservar las restricciones definidas en el diseno.	Captura del flujo y registro disponible.	Preparado
V-07	A07	Fallos de autenticacion	Formulario de inicio de sesion	Preparar intentos repetidos controlados de autenticacion.	Debe aplicarse la limitacion y registro definidos para el acceso.	Respuesta HTTP, captura y registro del WAF.	Preparado
V-08	A08	Integridad de software o datos	Repositorio / archivos desplegados	Revisar trazabilidad de cambios y controles sobre archivos.	Los cambios deben quedar identificados y proceder de fuentes autorizadas.	Historial de cambios, commit y captura.	Preparado
V-09	A09	Registro y alertas de	Logs del WAF / aplicacion	Generar posteriormente una solicitud controlada para comprobar el registro.	El evento debe registrar fecha, origen, recurso y regla o motivo.	Captura del log y detalle del evento.	Preparado

Criterios | Matriz Riesgos OWASP | Resumen | Verificacion Fase 2

```bash
#!/bin/bash
# ------------------------------------------------------------------------------
# PROYECTO: WAF Shield Cloud - Grupo SN-2
# DESCRIPCIÓN: Script de despliegue automatizado de política perimetral en GCP
# AUTOR: Mauricio Alberto Grande Martínez
# ------------------------------------------------------------------------------

# 1. Crear la política de seguridad perimetral en Cloud Armor
gcloud compute security-policies create waf-shield-sn2-policy \
    --description="Politica perimetral WAF Shield Cloud - Grupo SN-2"

# 2. Regla 1000: Rate Limiting en /login (Mitigación de Fuerza Bruta)
# Restringe a máximo 5 peticiones por minuto por dirección IP; banea por 5 minutos al exceder.
gcloud compute security-policies rules create 1000 \
    --security-policy=waf-shield-sn2-policy \
    --expression="request.path.matches('/login')" \
    --action="rate-based-ban" \
    --rate-limit-threshold-count=5 \
    --rate-limit-threshold-interval-sec=60 \
    --ban-duration-sec=300 \
    --conform-action="allow" \
    --exceed-action="deny(403)" \
    --enforce-on-key="IP"

# 3. Regla 2000: Protección contra Inyección SQL (SQLi en L7)
# Utiliza el conjunto de reglas preconfiguradas de OWASP para SQLi
gcloud compute security-policies rules create 2000 \
    --security-policy=waf-shield-sn2-policy \
    --expression="evaluatePreconfiguredExpr('sqli-v933100')" \
    --action="deny(403)"

# 4. Regla 3000: Protección contra Cross-Site Scripting (XSS en L7)
# Utiliza el conjunto de reglas preconfiguradas de OWASP para XSS
gcloud compute security-policies rules create 3000 \
    --security-policy=waf-shield-sn2-policy \
    --expression="evaluatePreconfiguredExpr('xss-v941100')" \
    --action="deny(403)"

# 5. Regla 4000: Restricción de acceso a rutas administrativas (/admin)
# Intercepta en el perímetro cualquier intento de acceso a la consola interna
gcloud compute security-policies rules create 4000 \
    --security-policy=waf-shield-sn2-policy \
    --expression="request.path.matches('/admin')" \
    --action="deny(403)"
```

```python
# ================================================================================
# SCRIPT DE AUDITORÍA Y LÍNEA BASE PERIMETRAL - WAF SHIELD CLOUD (GRUPO SN-2)
# Entorno: Docker Sandbox Local (http://localhost:3000)
# ================================================================================

import requests
import time

BASE_URL = "http://localhost:3000"

def print_header(title):
    print(f"\n--- {title} ---")

print("================================================================================")
print(" AUDITORÍA SECLINE DE LÍNEA BASE PERIMETRAL - GRUPO SN-2")
print("================================================================================")

# 1. SALUD DEL SERVICIO
print_header("1. SALUD DEL SERVICIO (GET /healthcheck)")
try:
    r = requests.get(f"{BASE_URL}/healthcheck")
    print(f"Estado: StatusCode = {r.status_code} -> Servicio Operativo Base")
except Exception as e:
    print(f"Estado: Error al conectar ({e})")

# 2. PRUEBA DE FUERZA BRUTA / RATE LIMITING
print_header("2. PRUEBA DE FUERZA BRUTA / RATE LIMITING (POST /login)")
payload_login = {"email": "demo@example.test", "password": "123"}
for i in range(1, 9):
    try:
        r = requests.post(f"{BASE_URL}/login", json=payload_login)
        print(f"Peticion {i}: StatusCode = {r.status_code} (Procesada por Express sin Rate Limit)")
    except Exception as e:
        print(f"Peticion {i}: Error ({e})")

# 3. SIMULACIÓN DE INYECCIÓN SQL - SQLi
print_header("3. SIMULACIÓN DE INYECCIÓN SQL - SQLi (POST /login)")
payload_sqli = {"email": "admin' OR '1'='1", "password": "123"}
try:
    r = requests.post(f"{BASE_URL}/login", json=payload_sqli)
    print(f"Inyeccion SQL: StatusCode = {r.status_code} (Llega al backend -> Mitigar con Regla 2000)")
except Exception as e:
    print(f"Inyeccion SQL: Error ({e})")

# 4. SIMULACIÓN DE CROSS-SITE SCRIPTING - XSS
print_header("4. SIMULACIÓN DE CROSS-SITE SCRIPTING - XSS (GET /search)")
try:
    r = requests.get(f"{BASE_URL}/search", params={"q": "<script>alert('XSS-Test')</script>"})
    if r.status_code == 200:
        data = r.json()
        print(f"XSS Reflejado en Query: '{data.get('query')}' -> StatusCode = 200 (Sin filtrado -> Mitigar con Regla 3000)")
    else:
        print(f"XSS: StatusCode = {r.status_code}")
except Exception as e:
    print(f"XSS: Error ({e})")

# 5. SIMULACIÓN DE CARGA MALICIOSA EN FORMULARIO
print_header("5. SIMULACIÓN DE CARGA MALICIOSA EN FORMULARIO (POST /comments)")
payload_xss_comment = {"comment": "<script>alert('xss')</script>"}
try:
    r = requests.post(f"{BASE_URL}/comments", json=payload_xss_comment)
    print(f"Comentario: StatusCode = {r.status_code} (Llega a la app -> Mitigar con Regla 2000/3000)")
except Exception as e:
    print(f"Comentario: Error ({e})")

# 6. VERIFICACIÓN DE RUTA RESTRINGIDA
print_header("6. VERIFICACIÓN DE RUTA RESTRINGIDA (GET /admin)")
try:
    r = requests.get(f"{BASE_URL}/admin")
    print(f"Ruta Admin: StatusCode = {r.status_code} (Restringida por backend -> Regla 4000 de respaldo)")
except Exception as e:
    print(f"Ruta Admin: Error ({e})")

print("\n================================================================================")
print(" FIN DE LA AUDITORÍA DE LÍNEA BASE - EVIDENCIA LISTA PARA DOCUMENTACIÓN")
print("================================================================================\n")

```

```python
# ================================================================================
# SCRIPT DE AUDITORÍA Y LÍNEA BASE PERIMETRAL - WAF SHIELD CLOUD (GRUPO SN-2)
# Entorno: Docker Sandbox Local (http://localhost:8080)
# ================================================================================

import requests
import time

BASE_URL = "http://localhost:8080"

def print_header(title):
    print(f"\n--- {title} ---")

print("================================================================================")
print(" AUDITORÍA SECLINE DE LÍNEA BASE PERIMETRAL - GRUPO SN-2")
print("================================================================================")

# 1. SALUD DEL SERVICIO
print_header("1. SALUD DEL SERVICIO (GET /healthcheck)")
try:
    r = requests.get(f"{BASE_URL}/healthcheck")
    print(f"Estado: StatusCode = {r.status_code} -> Servicio Operativo Base")
except Exception as e:
    print(f"Estado: Error al conectar ({e})")

# 2. PRUEBA DE FUERZA BRUTA / RATE LIMITING
print_header("2. PRUEBA DE FUERZA BRUTA / RATE LIMITING (POST /login)")
payload_login = {"email": "demo@example.test", "password": "123"}
for i in range(1, 9):
    try:
        r = requests.post(f"{BASE_URL}/login", json=payload_login)
        print(f"Peticion {i}: StatusCode = {r.status_code} (Procesada por Express sin Rate Limit)")
    except Exception as e:
        print(f"Peticion {i}: Error ({e})")

# 3. SIMULACIÓN DE INYECCIÓN SQL - SQLi
print_header("3. SIMULACIÓN DE INYECCIÓN SQL - SQLi (POST /login)")
payload_sqli = {"email": "admin' OR '1'='1", "password": "123"}
try:
    r = requests.post(f"{BASE_URL}/login", json=payload_sqli)
    print(f"Inyeccion SQL: StatusCode = {r.status_code} (Llega al backend -> Mitigar con Regla 2000)")
except Exception as e:
    print(f"Inyeccion SQL: Error ({e})")

# 4. SIMULACIÓN DE CROSS-SITE SCRIPTING - XSS
print_header("4. SIMULACIÓN DE CROSS-SITE SCRIPTING - XSS (GET /search)")
try:
    r = requests.get(f"{BASE_URL}/search", params={"q": "<script>alert('XSS-Test')</script>"})
    if r.status_code == 200:
        data = r.json()
        print(f"XSS Reflejado en Query: '{data.get('query')}' -> StatusCode = 200 (Sin filtrado -> Mitigar con Regla 3000)")
    else:
        print(f"XSS: StatusCode = {r.status_code}")
except Exception as e:
    print(f"XSS: Error ({e})")

# 5. SIMULACIÓN DE CARGA MALICIOSA EN FORMULARIO
print_header("5. SIMULACIÓN DE CARGA MALICIOSA EN FORMULARIO (POST /comments)")
payload_xss_comment = {"comment": "<script>alert('xss')</script>"}
try:
    r = requests.post(f"{BASE_URL}/comments", json=payload_xss_comment)
    print(f"Comentario: StatusCode = {r.status_code} (Llega a la app -> Mitigar con Regla 2000/3000)")
except Exception as e:
    print(f"Comentario: Error ({e})")

# 6. VERIFICACIÓN DE RUTA RESTRINGIDA
print_header("6. VERIFICACIÓN DE RUTA RESTRINGIDA (GET /admin)")
try:
    r = requests.get(f"{BASE_URL}/admin")
    print(f"Ruta Admin: StatusCode = {r.status_code} (Restringida por backend -> Regla 4000 de respaldo)")
except Exception as e:
    print(f"Ruta Admin: Error ({e})")

print("\n================================================================================")
print(" FIN DE LA AUDITORÍA DE LÍNEA BASE - EVIDENCIA LISTA PARA DOCUMENTACIÓN")
print("================================================================================\n")

```

```
events {
    worker_connections 1024;
}

http {
    limit_req_zone $binary_remote_addr zone=login_limit:10m rate=5r/m;

    server {
        listen 8080;

        # Regla 1000: Rate Limiting en /login (Sin ráfaga / nodelay)
        location /login {
            limit_req zone=login_limit nodelay;
            limit_req_status 403;
            proxy_pass http://host.docker.internal:3000;
        }

        # Regla 4000: Bloqueo de /admin
        location /admin {
            return 403;
        }

        # Tráfico general (Default Allow)
        location / {
            proxy_pass http://host.docker.internal:3000;
        }
    }
}
```

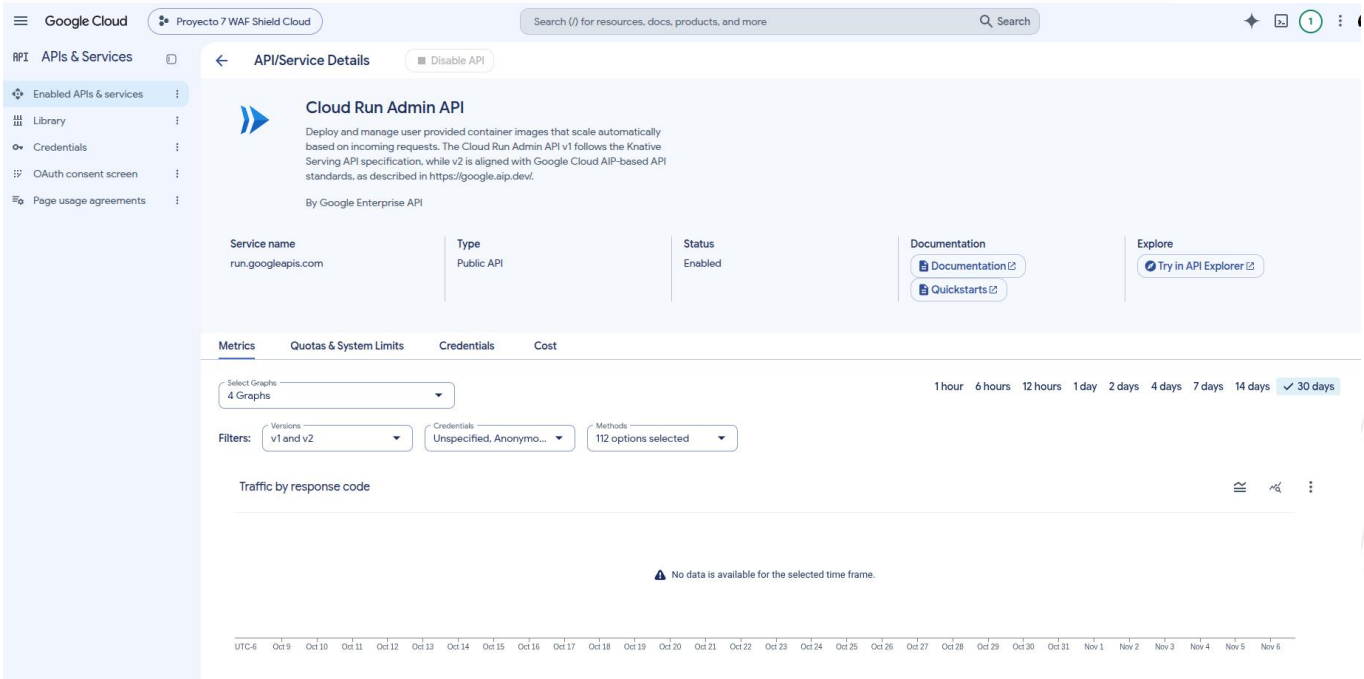
Evidencia 4: EV05 y EV06 - Configuración cloud, validaciones y reuniones reportadas.

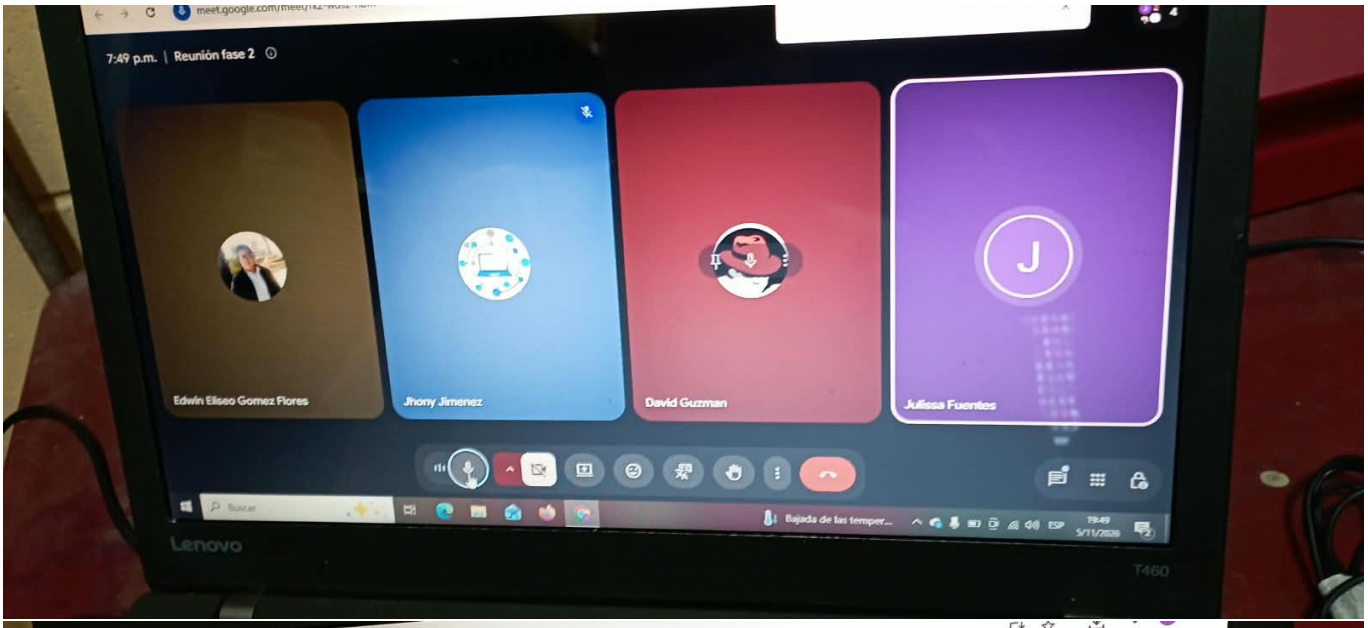


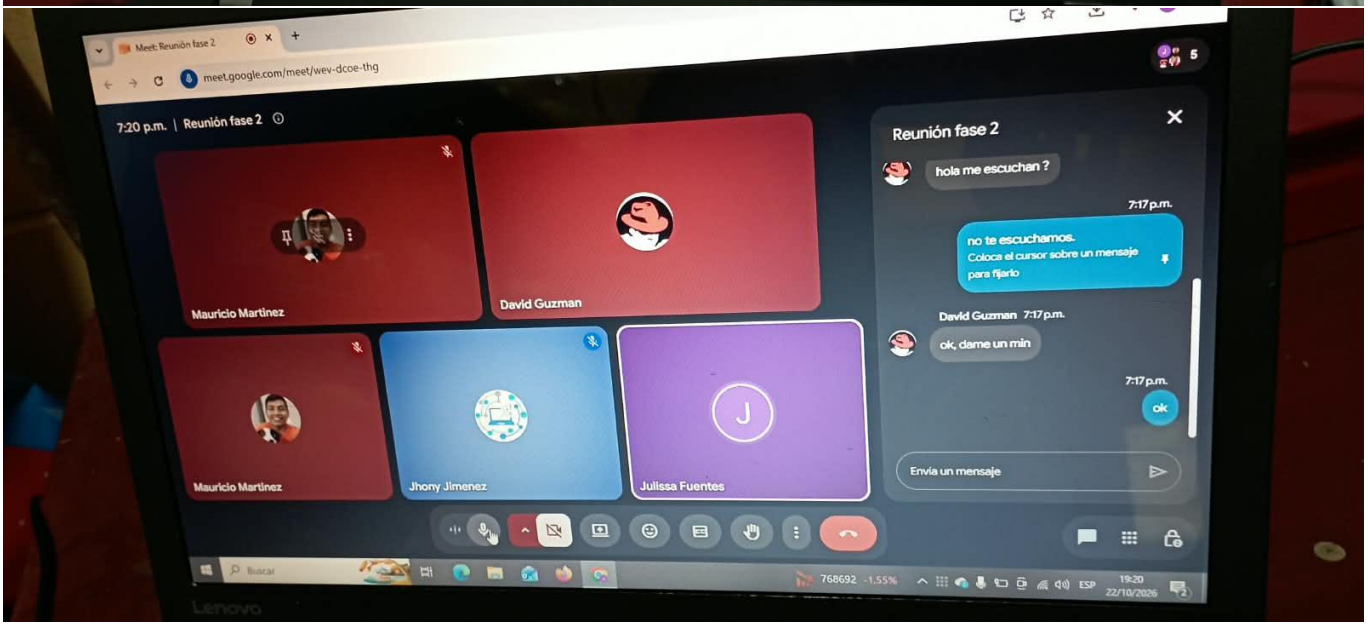
E2-10 — Validación del código fuente

✓ Estructura y contenido del código verificados

Componente	Resultado
`package.json`	Válido; Node.js 20+ y Express 5.1
`package-lock.json`	Presente
`src/app.js`	Aplicación Express con rutas de prueba
`src/server.js`	Compatible con `PORT` y `0.0.0.0`
`public/`	Interfaz web de Universidad Nova Digital
`test/app.test.js`	Pruebas automatizadas incluidas
`README.md`	Instrucciones de ejecución documentadas




7:49 p.m. | Reunión fase 2
Edwin Eliseo Gomez Flores
Jhony Jimenez
David Guzman
J
Julissa Fuentes
Lenovo
T460


meet.google.com/meet/wev-dcoe-thg
7:20 p.m. | Reunión fase 2
Mauricio Martinez
David Guzman
Mauricio Martinez
Jhony Jimenez
J
Julissa Fuentes
Reunión fase 2
hola me escuchan ?
7:17 p.m.
no te escuchamos.
Coloca el cursor sobre un mensaje para fijarlo
David Guzman 7:17 p.m.
ok, dame un min
7:17 p.m.
ok
Envía un mensaje
Lenovo